

Checklist

The Extra Mile

Email Server Security

Configuration

- ☐ Confirm the mail server is **not configured as an open relay**.
- ☐ Restrict mail relay to authorized domains and users only.
- ☐ Verify the SMTP **HELO/EHLO hostname** correctly identifies the mail server.
- ☐ Ensure the server hostname matches the appropriate public DNS records.
- ☐ Check that the mail server has a valid **reverse DNS (PTR) record**.
- ☐ Confirm forward DNS and reverse DNS records are consistent.
- ☐ Check the mail server/IP against common email blocklists.
- ☐ Review other common mail-server misconfigurations with tools such as MXToolbox.
- ☐ Confirm spam and phishing filtering is enabled and properly configured.

Email Administration

- ☐ Use **role-based aliases** instead of relying entirely on individual employee accounts.
- ☐ Use group nesting where appropriate to simplify alert and licensing distribution.
- ☐ Route security alerts to shared groups rather than one person.
- ☐ Create shared aliases for functions such as licensing, certificates, and renewals.
- ☐ Make sure important operational mail continues to reach the correct team after personnel changes.
- ☐ Review whether operating an internal mail server is worth the administrative and security overhead.
- ☐ Consider a managed email provider if your organization cannot securely maintain its own mail infrastructure.

DNS Server Security

Recursion and Exposure

- ☐ Disable **recursive DNS queries** on authoritative DNS servers that do not need recursion.
- ☐ Restrict recursive DNS access to authorized internal systems.
- ☐ Prevent public systems from unnecessarily querying internal DNS servers.
- ☐ Allow external-facing DNS queries only where required.

Internal and External DNS

- ☐ Separate **internal DNS** and **external DNS** services where practical.
- ☐ Configure internet-facing systems to use appropriate external resolvers.
- ☐ Keep internal-only hostnames and DNS information from being unnecessarily exposed.

Zone Transfers

- ☐ Restrict DNS **zone transfers (AXFR)** to trusted name servers only.
- ☐ Verify unauthorized systems cannot retrieve complete DNS zone information.
- ☐ Review DNS records for unnecessary disclosure of internal infrastructure.

Passive DNS Monitoring

- ☐ Consider implementing **passive DNS monitoring**.
- ☐ Collect DNS queries, responses, and errors for centralized analysis.
- ☐ Review DNS telemetry for newly registered or suspicious domains.
- ☐ Use DNS monitoring to support malware detection and incident investigation.

DNS Sinkhole / RPZ

- ☐ Consider deploying a **DNS sinkhole** for known malicious domains.
- ☐ Maintain or subscribe to a reliable malicious-domain list.
- ☐ Configure bad domains to return an error or non-routable response.
- ☐ Consider using **Response Policy Zone (RPZ)** records.
- ☐ Monitor sinkhole events for infected or compromised internal systems.

DNSSEC

- ☐ Evaluate DNSSEC carefully before deployment.
- ☐ Do not implement DNSSEC solely because it appears more secure.
- ☐ Account for the added infrastructure complexity and operational risk.
- ☐ Consider whether the additional DNSSEC response size could increase DDoS amplification exposure.
- ☐ Deploy DNSSEC only when its benefits clearly outweigh the added risk and management burden.

Security Through Obscurity

Useful Supplemental Measures

- ☐ Consider placing administrative services on **nonstandard ports** when appropriate.
- ☐ Consider renaming default administrative accounts.
- ☐ Configure service banners so they do not unnecessarily reveal the operating system or software version.
- ☐ Treat obscurity measures only as an **additional layer**, never as the primary security control.

Avoid

- ☐ Do **not** assume changing ports makes a vulnerable service secure.
- ☐ Do **not** rely on blocking Shodan or other internet scanners as a security strategy.
- ☐ Do **not** label systems or equipment with overly descriptive names that reveal their function.
- ☐ Do **not** place an internet-facing device or service online before vulnerability testing.
- ☐ Do **not** depend on hidden names, ports, or services instead of proper patching, authentication, access control, and monitoring.

Ongoing Security Learning

Books

- ☐ Review *Blue Team Handbook: Incident Response Edition*.
- ☐ Review *Building an Information Security Awareness Program*.
- ☐ Review *Complete Guide to Shodan*.
- ☐ Review *Designing and Building a Security Operations Center*.
- ☐ Review resources on ICS/SCADA security where relevant.
- ☐ Review resources on developing and implementing a security master plan.

Blogs and Security News

- ☐ Follow reputable security sources such as CISA, Krebs on Security, Mandiant, SANS Internet Storm Center, and similar organizations.
- ☐ Regularly review current threat intelligence and incident reports.
- ☐ Track newly disclosed vulnerabilities affecting technologies your organization uses.

Podcasts

- ☐ Subscribe to one or more trusted cybersecurity podcasts.
- ☐ Use podcasts to stay current on threat intelligence, defensive techniques, and security news.

Useful Websites and Tools

- ☐ Bookmark **CISA** resources.
- ☐ Bookmark the **NIST National Vulnerability Database**.
- ☐ Track upcoming security competitions or CTFs if useful for skill development.
- ☐ Maintain access to trusted malware-analysis and threat-intelligence resources.
- ☐ Keep OSINT tools and frameworks available for investigations.
- ☐ Maintain trusted vulnerability-testing and configuration-baseline references.
- ☐ Periodically review security bookmarks and remove outdated or untrusted sources.

Final Review

- ☐ Email servers are securely configured and not open relays.
- ☐ Mail DNS, reverse DNS, and hostname settings are correct.
- ☐ Critical email communication uses resilient role-based groups or aliases.
- ☐ DNS recursion is restricted.

- ☐ Internal and external DNS functions are appropriately separated.
- ☐ Zone transfers are limited to trusted systems.
- ☐ DNS activity is monitored for suspicious domains and behavior.
- ☐ DNS sinkholing is considered or implemented where appropriate.
- ☐ Security-through-obscurity techniques are never treated as primary controls.
- ☐ Internet-facing systems are tested before deployment.
- ☐ Security staff have an ongoing process for learning about new threats, vulnerabilities, and defensive techniques.